Matriz de trazabilidad ERS B: 40 de 40 requisitos

Sección 4 del informe EP3 · Cuidarte+ (Caso B) · Elaborado por Giannina Guerrero · 19 de octubre de 2026

4.1 Criterio de construcción

En la EV1 la matriz relacionaba 11 filas con seis casos de prueba y dejaba fuera 21 de los 40 códigos del ERS B. Para la EP3 la reconstruí completa: cada requisito funcional, no funcional y regla de negocio tiene ahora un caso de prueba asignado, con un identificador que no va a cambiar durante la ejecución. Los casos CP-01 a CP-06 se mantienen desde la EV1 con el mismo número, para no romper la relación con los anexos y las evidencias ya entregadas. Los casos CP-07 a CP-23 son nuevos y los numeré siguiendo el orden de las brechas que el propio informe EV1 había reconocido en la sección 5.2.

La columna Riesgo usa la priorización de la estrategia (sección 3.1): P0 corresponde a autenticación, control de acceso y documentos clínicos; P1 a auditoría, registros y respaldo; P2 al CRUD clínico; P3 a rendimiento y disponibilidad, y P4 a usabilidad y compatibilidad. La columna Incidente vinculado indica el defecto que la revisión estática del código hace esperar en ese caso (detalle en la Tabla 6.2 del análisis ético y normativo). OC-01 no es un defecto del software, sino una observación de cumplimiento sobre la propia regla RB-3. La columna Resultado registra lo que mostró la ejecución del 20 y del 26 de octubre de 2026 y la revisión de CP-17 del 27 de octubre. Al cierre quedan 10 códigos aprobados, 10 parciales, 18 fallidos y 2 sin ejecutar al 27 de octubre de 2026, porque CP-19 no se corrió.

Tres verificaciones no se hacen desde la interfaz: TLS (CP-14), cifrado en reposo (CP-16) y respaldo (CP-18). Las clasifiqué como verificación de configuración, que es como la EV1 ya las describía en la sección 5.2. Se ejecutan revisando archivos de despliegue y la base de datos, y cuentan igual para la cobertura porque tienen resultado esperado y criterio de aceptación.

4.2 Requisitos funcionales (17)

Tabla 4.1. Trazabilidad de los requisitos funcionales

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
RF-1.1	Autenticarse con nombre_usuario y contraseña	CP-01	Funcional y seguridad	P0	Autenticación	Nicolás	INC-01, INC-02	Aprobado. Bitácora CP-01
RF-1.2	Cierre de sesión y revocación de tokens	CP-07	Seguridad de sesión	P0	Autenticación	Nicolás	INC-03	Fallido, INC-03. Bitácora CP-07
RF-2.1	Registro rápido con usuario, contraseña y correo; rol paciente por defecto	CP-09	Funcional; valores límite	P2	Registro	Nicolás	INC-10	Parcial: alta vía administrador; /registro público sin

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
								probar. Bitácora CP-09
RF-2.2	Médico o administrador registra a un paciente	CP-10	Funcional	P2	Pacientes	Nicolás	Ninguno	Parcial: se probó la edición, no el alta del paciente. Bitácora CP-10
RF-2.3	Médico o administrador edita el registro de un paciente	CP-10	Funcional	P2	Pacientes	Nicolás	Ninguno	Aprobado. Bitácora CP-10
RF-2.4	Médico o administrador visualiza el registro de un paciente	CP-10	Funcional; control de acceso	P0	Pacientes	Nicolás	OC-01	Aprobado. Bitácora CP-10
RF-2.5	Administrador visualiza los usuarios registrados	CP-08	Funcional; RBAC	P0	Usuarios	Nicolás	Ninguno	Aprobado. Bitácora CP-08
RF-2.6	Administrador edita un usuario y le asigna roles	CP-08	Funcional; RBAC	P0	Usuarios y roles	Nicolás	INC-07	Parcial: sin evidencia de edición de rol; INC-07 sin probar. Bitácora CP-08
RF-2.7	Administrador elimina un usuario	CP-08	Funcional; auditoría	P0	Usuarios	Nicolás	INC-09	Parcial: se vio la confirmación; baja lógica sin verificar (INC-09). Bitácora CP-08
RF-3.1	Médico registra un examen a un paciente	CP-02	Funcional	P2	Exámenes	Nicolás	INC-04	Aprobado. Bitácora CP-02
RF-3.2	Médico edita el examen y sus documentos	CP-11	Funcional	P2	Exámenes y documentos	Nicolás	Ninguno	Aprobado. Bitácora CP-11
RF-3.3	Médico elimina el examen o sus documentos (baja lógica con confirmación)	CP-11	Funcional; cumplimiento	P1	Exámenes y documentos	Nicolás	INC-09	Parcial: el médico no tiene opción de eliminar;

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
								INC-09 sin probar. Bitácora CP-11
RF-4.1	Paciente visualiza sus exámenes	CP-12	Funcional; control de acceso	P0	Exámenes (vista paciente)	Nicolás	Ninguno	Aprobado. Bitácora CP-12
RF-4.2	Paciente descarga los documentos de sus exámenes (máximo 10 s)	CP-13	Funcional; rendimiento	P0	Documentos	Nicolás (flujo) y Ari (tiempo)	INC-12, INC-13	Parcial: la descarga funciona pero no se audita (INC-13); el tiempo de 10 s no se midió. Bitácora CP-03 y CP-13
RF-4.3	Médico adjunta un documento por examen en PDF, DOC, PPT, JPG o PNG	CP-13	Funcional; partición de equivalencia	P2	Documentos	Nicolás	INC-15	Fallido, INC-15. Bitácora CP-13
RF-4.4	Documentos en storage interno y referenciados en la BD	CP-13	Integración	P1	Documentos y BD	Nicolás	INC-16	Fallido, INC-16. Bitácora CP-13 y Tabla 24 CP-16
RF-5.1	Auditar creación, edición, eliminación y subida o descarga de documentos	CP-03	Funcional; cumplimiento	P1	Auditoría	Nicolás	INC-13, INC-14	Fallido, INC-13 e INC-14. Bitácora CP-03

4.3 Requisitos no funcionales (20)

Tabla 4.2. Trazabilidad de los requisitos no funcionales

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
NFR-SEG-1	TLS obligatorio en todas las comunicaciones	CP-14	Seguridad; verificación de configuración	P0	Transversal (nginx y API)	Skarlett	Ninguno	Fallido. Tabla 24 CP-14
NFR-SEG-2	Contraseñas con hashing seguro (bcrypt)	CP-15 y CP-	Seguridad	P0	Autenticación y BD	Ari	INC-01, INC-	Fallido,

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
		01					10	INC-01. Contraseñas en texto plano y John the Ripper sin hashes que cargar. Tabla 24 CP-15
NFR-SEG-3	Cifrado de datos sensibles en reposo	CP-16	Seguridad; verificación de configuración	P0	BD y storage	Skarlett	Ninguno	Fallido, INC-16. Tabla 24 CP-16
NFR-SEG-4	Control de acceso por rol en el backend	CP-04 y CP-08	Seguridad	P0	Transversal	Ari	INC-07	Parcial: el paciente recibe 403 al escribir o pedir datos ajenos y el médico 403 en /usuarios. /roles no pide token según el código (INC-07), sin prueba dinámica. Tabla 24 CP-04 y CP-08
NFR-SEG-5	Protección contra CSRF, XSS e inyección SQL; validación y saneamiento	CP-04	Seguridad	P0	Transversal	Ari (ZAP y curl) y Nicolás (SQLMap)	INC-05, INC-08	Parcial: SQLMap sin inyección y ZAP autenticado sin alertas altas; CORS abierto y sin cabeceras

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
								de seguridad (INC-05). Tabla 24 CP-04
NFR-SEG-6	Gestión de log segura	CP-17	Seguridad; cumplimiento	P1	Auditoría y manejo de errores	Skarlett (SonarQube) y Ari	INC-06, INC-14	Fallido, INC-06 confirmado en el código (34 bloques catch con err.message) e INC-14 confirmado en CP-03. Tabla 24 CP-17
NFR-SEG-7	Políticas de respaldo y recuperación definidas	CP-18	Operación; verificación de configuración	P1	Infraestructura	Skarlett	Ninguno	Fallido. Tabla 24 CP-18
NFR-SEG-8	Cumplimiento de la normativa de protección de datos personales	CP-23 (con CP-03 y CP-04)	Cumplimiento normativo	P0	Transversal	Giannina	INC de seguridad	Fallido: DS 41 arts. 8 y 9 y Ley 20.584 art. 13 no se cumplen. Tabla 24 CP-23
NFR-SEG-9	Manejo de sesión con token de acceso (JWT)	CP-01 y CP-07	Seguridad de sesión	P0	Autenticación	Nicolás y Ari	INC-02, INC-03, INC-08	Fallido, INC-03. Bitácora CP-07
NFR-PERF-1	CRUD simple bajo 300 ms con carga normal	CP-05	Rendimiento	P3	API	Ari	INC-04	Fallido, INC-04. Con el retraso las consultas tardan 5 s; sin retraso no se midió. Tabla 24 CP-05
NFR-PERF-2	Página principal bajo 2 s en conexión móvil promedio	CP-19	Rendimiento	P3	Frontend	Ari (Skarlett apoya con Lighthouse)	Ninguno	No ejecutado

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
								al 27 oct 2026, CP-19 sin correr
NFR-PERF-3	200 usuarios concurrentes por defecto	CP-19	Carga	P3	API	Ari	INC-04	No ejecutado al 27 oct 2026, CP-19 sin correr
NFR-USAB-1	Tipografía legible, contraste y controles grandes para personas mayores	CP-06	Usabilidad; accesibilidad	P4	Frontend	Skarlett	Ninguno	Fallido. Tabla 24 CP-06
NFR-USAB-2	Flujos claros de registro y de visualización de exámenes o documentos	CP-06	Usabilidad	P4	Frontend	Skarlett	INC-12	Parcial: INC-12 no se reejecutó, sin documentos. Tabla 24 CP-06
NFR-USAB-3	Ayuda contextual y mensajes de error amigables	CP-20	Usabilidad	P4	Frontend	Skarlett	INC-06	Fallido. INC-06 no se reprodujo en el login, pero está confirmado en el código (CP-17). Tabla 24 CP-20
NFR-USAB-4	Primero se accede al paciente y luego a sus exámenes	CP-06	Usabilidad; flujo	P4	Frontend	Skarlett	Ninguno	Fallido. Tabla 24 CP-06
NFR-DIS-1	Disponibilidad objetivo de 99,5 % mensual	CP-21	Disponibilidad; verificación documental	P3	Infraestructura	Ari	INC-17	Fallido, INC-17. Una sola réplica y sin medición del 99,5 %. Tabla 24 CP-21
NFR-DIS-2	Mantenimiento con ventana y migración segura de datos	CP-21	Mantenibilidad; verificación	P3	Infraestructura	Ari	INC-17	Fallido, INC-17.

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
			documental					Sin ventana de mantenimiento ni respaldo automático. Tabla 24 CP-21
NFR-COMPAT-1	Últimas dos versiones de Chrome, Firefox, Safari y Edge	CP-22	Compatibilidad	P4	Frontend	Skarlett	Ninguno	Parcial: Chrome y Edge aprobados; Firefox y Safari sin probar. Tabla 24 CP-22
NFR-COMPAT-2	Responsivo en móviles y tablets	CP-06	Compatibilidad	P4	Frontend	Skarlett	Ninguno	Fallido. Tabla 24 CP-06

4.4 Reglas de negocio (3)

Tabla 4.3. Trazabilidad de las reglas de negocio

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
RB-1	Un paciente solo tiene permisos de lectura	CP-04	Seguridad; RBAC	P0	Transversal	Ari	Ninguno	Aprobado: con token de paciente las escrituras y los datos ajenos responden 403; /roles no se incluyó. Tabla 24 CP-04
RB-2	El administrador tiene acceso completo de escritura, lectura, actualización y eliminación	CP-08	Funcional; RBAC	P0	Usuarios	Nicolás	INC-07, OC-01	Aprobado. Bitácora CP-08
RB-3	Un médico puede ver la información clínica	CP-10 y CP-	Funcional;	P0	Pacientes y	Nicolás	OC-01	Aprobado;

Código	Descripción (ERS B)	Caso	Tipo de prueba	Riesgo	Módulo	Ejecuta	Incidente vinculado	Resultado
	de cualquier paciente registrado	02	cumplimiento		exámenes			OC-01 se analiza en la sección 6. Bitácora CP-10 y CP-02

4.5 Catálogo de casos de prueba

La tabla siguiente es la vista inversa de la matriz. Muestra qué requisitos cubre cada caso, con qué herramienta se ejecutó y quién lo ejecuta. Con Selenium se ejecutó el 27 de octubre de 2026 una suite de 11 pruebas de interfaz sobre CP-01, 02, 07, 08, 10, 11 y 12, y las 11 pasaron. Los casos negativos y el control de acceso en la API se probaron a mano y con Postman. Burp Suite y Nikto estaban en el diseño, pero no se usaron y se reemplazaron por Swagger y curl. Los seis casos de la EV1 ya cuentan con su ficha completa (descripción, requerimiento, datos, resultado esperado, criterio de aceptación y tipo de prueba), así que el informe tiene más de los cinco casos detallados que se nos pidieron para la EP3. Los casos CP-07 y CP-08 se agregan con ficha completa en el punto 4.8 porque cubren brechas que la EV1 dejó declaradas.

Tabla 4.4. Casos de prueba de la EP3

Caso	Nombre	Códigos ERS cubiertos	Herramienta	Ejecuta	Origen
CP-01	Autenticación válida y rechazo de credenciales inválidas	RF-1.1, NFR-SEG-2, NFR-SEG-9	UI manual, Postman/Swagger y Selenium (AUTH-01 y AUTH-02, 27 oct 2026)	Nicolás	EV1 (detallado)
CP-02	Registro de examen médico por un profesional autorizado	RF-3.1, RB-3	UI manual y Postman. Selenium cubrió el listado de exámenes (EXA-01)	Nicolás	EV1 (detallado)
CP-03	Registro de auditoría ante acciones críticas, incluida la subida y la descarga	RF-5.1, NFR-SEG-8	Postman, consulta a la tabla auditoria	Nicolás	EV1, ampliado en EP3
CP-04	Control de acceso por rol y resistencia a inyección	NFR-SEG-4, NFR-SEG-5, NFR-SEG-8, RB-1	OWASP ZAP autenticado, SQLMap, Swagger y curl. Burp Suite y Nikto reemplazados por Swagger y curl	Ari y Nicolás	EV1 (detallado)
CP-05	Tiempo de respuesta de operaciones CRUD con y sin el retraso de 5 s	NFR-PERF-1	JMeter	Ari	EV1, se repite sin delay
CP-06	Usabilidad para adulto mayor y compatibilidad responsive	NFR-USAB-1, 2 y 4, NFR-COMPAT-2	Lista de verificación manual, Lighthouse	Skarlett	EV1 (detallado)
CP-07	Cierre de sesión y revocación del token	RF-1.2, NFR-SEG-9	Postman/Swagger y Selenium en la interfaz (AUTH-03)	Nicolás	Nuevo (ficha en 4.8)
CP-08	Administración de usuarios por el administrador: listar, editar rol y eliminar	RF-2.5, 2.6, 2.7, NFR-SEG-4, RB-2	UI manual, Postman y Selenium (RBAC-01 y RBAC-02)	Nicolás	Nuevo (ficha en 4.8)
CP-09	Registro rápido con rol paciente y política de contraseña	RF-2.1	UI manual, sin Selenium	Nicolás	Nuevo
CP-10	Gestión de pacientes por médico y administrador	RF-2.2, 2.3, 2.4, RB-3	UI manual, Postman y Selenium (PAC-01 y PAC-02)	Nicolás	Nuevo

Caso	Nombre	Códigos ERS cubiertos	Herramienta	Ejecuta	Origen
CP-11	Edición y baja lógica de exámenes y documentos con confirmación	RF-3.2, RF-3.3	UI manual, Postman y Selenium (EXA-01 y EXA-02)	Nicolás	Nuevo
CP-12	El paciente ve solo sus propios exámenes	RF-4.1	UI manual, Postman y Selenium (RES-01 y RBAC-03)	Nicolás	Nuevo
CP-13	Carga y descarga de documentos: formatos, almacenamiento y tiempo	RF-4.2, 4.3, 4.4	Postman, JMeter (tiempos)	Nicolás y Ari	Nuevo
CP-14	Verificación de TLS en frontend y API	NFR-SEG-1	Revisión de nginx.conf y docker-compose, navegador y curl. Nikto reemplazado por curl	Skarlett	Nuevo (configuración)
CP-15	Almacenamiento de contraseñas y resistencia a cracking	NFR-SEG-2	Consulta a la BD de prueba, John the Ripper	Ari	Nuevo
CP-16	Cifrado en reposo de datos clínicos y documentos	NFR-SEG-3	Revisión del esquema y de la carpeta uploads, SonarQube	Skarlett	Nuevo (configuración)
CP-17	Gestión de log y manejo de errores sin fuga de información	NFR-SEG-6	SonarQube, Swagger, curl y revisión manual del código. Burp Suite reemplazado por Swagger y curl	Skarlett y Ari	Nuevo
CP-18	Respaldo y restauración de la base de datos	NFR-SEG-7	pg_dump y restauración en Docker	Skarlett	Nuevo (configuración)
CP-19	Carga de la página principal y 200 usuarios concurrentes	NFR-PERF-2, NFR-PERF-3	Lighthouse, JMeter	Ari	Nuevo
CP-20	Ayuda contextual y mensajes de error comprensibles	NFR-USAB-3	Lista de verificación manual	Skarlett	Nuevo
CP-21	Disponibilidad y procedimiento de mantenimiento	NFR-DIS-1, NFR-DIS-2	Revisión documental y de docker-compose	Ari	Nuevo (documental)
CP-22	Compatibilidad con navegadores	NFR-COMPAT-1	Revisión manual en Chrome y Edge. Firefox y Safari bloqueados; sin Selenium	Skarlett	Nuevo
CP-23	Verificación de cumplimiento normativo	NFR-SEG-8	Checklist de la Tabla 6.1 del análisis normativo	Giannina	Nuevo (checklist)

4.6 Cobertura

Tabla 4.5. Cobertura de diseño, EV1 frente a EP3

Bloque	Códigos en el ERS	Con caso en la EV1 (tabla 5.1)	Tocados en forma indirecta en la EV1	Sin caso en la EV1	Con caso en la EP3
Requisitos funcionales	17	4	3	10	17
Requisitos no funcionales	20	8	2	10	20
Reglas de negocio	3	2	0	1	3
Total	**40**	**14**	**5**	**21**	**40**

La cobertura de diseño queda en 40 de 40 (100 %). Esto significa que ningún código del ERS queda sin un caso que lo verifique, pero no dice nada todavía sobre si el sistema cumple. En la EV1 la columna Cobertura marcaba como Cubierto todo requisito que tuviera un

caso diseñado; en la EP3 separamos las dos cosas. La cobertura de diseño se mide con esta matriz y la cobertura de ejecución con la columna Resultado, que hoy tiene valor en 38 de los 40 códigos según la bitácora de la sección 5.2.

Hay dos situaciones del ERS que conviene dejar explícitas para que nadie las lea como error de la matriz. RF-5.1 menciona la auditoría de "clientes, contratos", que son entidades del Caso A; se interpreta sobre pacientes, exámenes, usuarios y documentos, que son las entidades reales de Cuidarte+. RF-4.3 acepta PDF, DOC, PPT, JPG y PNG, pero el filtro de carga del backend (BACKEND/src/routes/documentos.js, líneas 15 a 27) solo admite PDF, JPG y PNG. CP-13 lo prueba con partición de equivalencia y, si la ejecución lo confirma, se registra como INC-15. En la misma línea, RF-4.4 pide guardar los documentos en storage interno con referencia en la base de datos, mientras que el backend guarda el archivo completo en la columna documento (tipo bytea) de la tabla documentos_examen; eso queda como INC-16 y lo revisa CP-13.

4.7 Cómo se completa durante la ejecución

Quien ejecuta un caso actualiza solo la columna Resultado de las filas que ese caso cubre y anota en la bitácora el identificador del defecto (BUG-xxx) cuando el resultado es Falla. Los identificadores CP no se renumeran. Si un caso necesita dividirse, se usa un sufijo (por ejemplo CP-10a y CP-10b), así la relación con la matriz, la bitácora y los incidentes sigue siendo la misma en todo el informe.

4.8 Fichas de los casos nuevos CP-07 y CP-08

Estas dos fichas siguen el formato institucional. Las escribí completas porque corresponden a las brechas C-02 y C-03 que la EV1 dejó abiertas, y así el caso queda listo para ejecutarse sin esperar otro diseño.

Tabla 4.6. Ficha del caso CP-07

Campo	Contenido
ID y nombre	CP-07. Cierre de sesión y revocación del token
Requerimiento	RF-1.2: El sistema debe soportar cierre de sesión y revocación de tokens. NFR-SEG-9: Manejo de sesión mediante token de acceso (JWT).
Descripción	Comprobar que, al cerrar sesión, el token emitido en el login deja de ser aceptado por la API, de modo que una sesión olvidada en un equipo compartido no siga abierta.
Precondiciones	Ambiente Docker local arriba (frontend en el puerto 3333 y API en el 4444). Usuario de prueba con rol médico y al menos un examen visible.
Pasos	1. Iniciar sesión con POST /autenticacion/login y guardar el token. 2. Consultar GET /examenes con ese token y confirmar respuesta 200. 3. Cerrar sesión desde la interfaz y, en paralelo, buscar en Swagger (/docs) un endpoint de logout o de revocación. 4. Repetir GET /examenes con el mismo token. 5. Registrar el código HTTP obtenido y el tiempo que el token sigue siendo aceptado.
Datos de entrada	Usuario de prueba con rol médico; token JWT obtenido en el paso 1.
Resultado esperado	Después del cierre de sesión la API responde 401 al token anterior. Existe un endpoint de logout que invalida el token en el servidor, como lo pide el ERS en la sección 3.1.2.
Criterio de aceptación	Logout invalida la sesión (criterio de aceptación de RF-1 en el ERS). Si el token sigue funcionando después del cierre de sesión, el caso falla aunque la interfaz vuelva a la pantalla de login.
Tipo de prueba	Seguridad de sesión (no funcional), con verificación funcional del flujo de cierre.
Incidente esperado	INC-03: en el código no existe ruta de logout y el token se emite con expiración de 2 horas (BACKEND/src/routes/auth.js, línea 54).

Tabla 4.7. Ficha del caso CP-08

Campo	Contenido
ID y nombre	CP-08. Administración de usuarios por el administrador
Requerimiento	RF-2.5, RF-2.6 y RF-2.7 (el administrador visualiza, edita con asignación de roles y elimina usuarios). NFR-SEG-4: Control de acceso por rol en backend. RB-2: el administrador tiene acceso completo.
Descripción	Verificar que el administrador puede gestionar usuarios de punta a punta y que ningún otro rol puede hacerlo, ni por la ruta de usuarios ni por la ruta de roles.
Precondiciones	Ambiente Docker local arriba. Cuentas de prueba con rol administrador y con rol médico. Un usuario de prueba sintético creado para ser editado y eliminado.
Pasos	1. Con token de administrador, listar usuarios con GET /usuarios. 2. Editar el usuario de prueba con PUT /usuarios/:id y asignarle el rol médico. 3. Eliminarlo desde la interfaz y confirmar que se pide confirmación antes de borrar. 4. Revisar GET /auditoria y la tabla de usuarios para ver si la baja fue lógica o física. 5. Con token de médico, repetir PUT /usuarios/:id y luego intentar POST /roles y DELETE /roles/:id.
Datos de entrada	Usuario sintético (por ejemplo, usuario.prueba08) con correo ficticio; tokens de administrador y de médico.
Resultado esperado	El administrador completa listar, editar y eliminar con respuestas 200. La eliminación pide confirmación, deja registro en auditoría y es lógica. Con token de médico, las rutas de usuarios y de roles responden 403.
Criterio de aceptación	Las tres operaciones funcionan solo para el rol administrador y el control de acceso se aplica en el backend. Cualquier operación de administración aceptada con un rol distinto hace fallar el caso.
Tipo de prueba	Funcional (RF-2.5 a 2.7) y de seguridad (control de acceso por rol).
Incidentes esperados	INC-07: /roles no verifica el rol del usuario (BACKEND/src/routes/roles.js, líneas 18 a 90). INC-09: la eliminación usa DELETE FROM (users.js, línea 574), es decir, borrado físico.